第9章 信息安全

枯燥的工程师

章节概述

9.1 信息系统安全体系
9.2 数据安全与保密
9.3 通信与网络安全技术
9.4 系统访问控制技术
9.5 容灾与业务持续
9.6 安全管理措施
9.7 系统可靠性
9.8 冗余技术
9.9 软件容错技术

主要内容：信息安全体系架构、加解密、网络安全、安全管理、可靠性、冗余和容错等。

题型分布：选择

考试分值：4—6分

学习方法：难度中等，理解为主，部分知识需理解性记忆。

淘宝搜索：系统分析师 规格严考

9.1 信息系统安全体系

1. 系统安全分类

（1）实体安全。指保护计算机设备、设施和其他媒体免遭地震、水灾、火灾、有害气体和其他环境事故破坏的措施和过程。

（2）运行安全。包括系统风险管理、审计跟踪、备份与恢复、应急等4个方面的内容。运行安全是计算机信息系统安全的重要环节，其实质是保证系统的正常运行，不因偶然的或恶意的侵扰而遭到破坏，使系统可靠、连续地运行，服务不受中断。

（3）信息安全。确保信息的保密性、完整性、可用性和可控性。

（4）人员安全。主要包括计算机使用人员的安全意识、法律意识和安全技能等。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.1 信息系统安全体系

2. 系统安全体系结构

（1）物理层安全。包括通信线路、物理设备和机房的安全等。

（2）操作系统安全。系统层的安全问题来自计算机网络内使用的操作系统的安全。

（3）网络安全。主要体现在计算机网络方面。

（4）应用安全。主要由提供服务所采用的应用软件和数据的安全性产生，以及病毒对系统的威胁。

（5）安全管理。包括安全技术和设备的管理、安全管理制度、组织规则等。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.1 信息系统安全体系

3. 安全保护等级

（1）用户自主保护级（第一级）。第一级的计算机信息系统可信计算机通过隔离用户与数据来实现，使用户具备自主安全保护的能力。适用于普通内联网用户。

（2）系统审计保护级（第二级）。第二级的计算机信息系统可信计算机实施了粒度更细的自主访问控制。适用于通过内联网或互联网进行商务活动，需要保密的非重要单位。

（3）安全标记保护级（第三级）。第三级的计算机信息系统可信计算机具有系统审计保护级的所有功能。适用于地方各级国家机关、金融机构、邮电通信、能源与水源供给部门、交通运输、大型工商与信息技术企业、重点工程建设等单位。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.1 信息系统安全体系

（4）结构化保护级（第四级）。它要求将第三级系统中的自主和强制访问控制扩展到所有主体与客体。第四级适用于中央级国家机关、广播电视部门、重要物资储备单位、社会应急服务部门、尖端科技企业集团、国家重点科研机构和国防建设等部门。

（5）访问验证保护级（第五级）。第五级的计算机信息系统可信计算机满足访问监控器需求。第五级适用于国防关键部门和依法需要对计算机信息系统实施特殊隔离的单位。

4. 系统安全保障系统

（1）建立统一的身份认证体系。

（2）建立统一的安全管理体系。

（3）建立规范的安全保密体系。

（4）建立完善的网络边界防护体系。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.2 数据安全与保密

数据加密技术

认证技术

密钥管理体制

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

数据加密技术

1、对称加密技术

数据的加密和解密的密钥（密码）是相同的，属于不公开密钥加密算法。其缺点是加密强度不高（因为密钥位数少），且密钥分发困难（因为密钥还需要传输给接收方，也要考虑保密性等问题）。优点是加密速度快，适合加密大数据。

常见的对称密钥加密算法如下：

DES：替换+移位、56位密钥、64位数据块、速度快，密钥易产生。

3DES：三重DES，两个56位密钥K1、K2。

加密：K1加密->K2解密->K1加密。

解密：K1解密->K2加密->K1解密

AES：是美国联邦政府采用的一种区块加密标准，这个标准用来替代原先的DES。对其的要求是“至少像3DES一样安全”。

RC-5：RSA数据安全公司的很多产品都使用了RC-5。

IDEA：128位密钥，64位数据块，比DES的加密性好，对计算机功能要求相对低。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

数据加密技术

2、非对称加密技术

数据的加密和解密的密钥是不同的，分为公钥和私钥。是公开密钥加密算法。其缺点是加密速度慢。优点是安全性高，不容易破解。

非对称技术的原理是：发送者发送数据时，使用接收者的公钥作加密密钥，私钥作解密密钥，这样只有接收者才能解密密文得到明文。安全性更高，因为无需传输密钥。但无法保证完整性。如下：

常见的非对称加密算法如下：

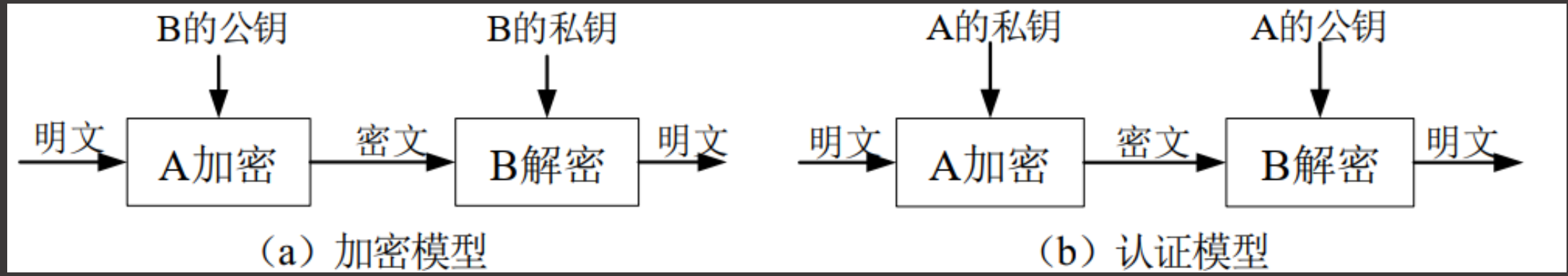
RSA：512位（或1024位）密钥，计算机量极大，难破解。

Elgamal、ECC（椭圆曲线算法）、背包算法、Rabin、D-H等。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

数据加密技术



微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

认证技术

认证又称为鉴别或确认，它是证实某事物是否名副其实或是否有效的过程。

1. 数字签名

数字签名的主要功能是保证信息传输的完整性、发送者的身份认证、防止交易中的抵赖发生。因此，不管使用哪种算法，数字签名必须保证以下三点：

（1）接收者能够核实发送者对数据的签名，这个过程称为鉴别，

（2）发送者事后不能抵赖对数据的签名，这称为不可否认。

（3）接收者不能伪造对数据的签名，这称为数据的完整性。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

认证技术

2. 数字签名算法

（1）杂凑算法。杂凑算法是主要的数字签名算法，它是利用散列（Hash）函数进行数据的加密。

（2）消息摘要算法。消息摘要算法（MD5）用于确保信息传输完整一致，经MD2、MD3和MD4发展而来。

（3）安全散列算法。安全散列算法（SHA）能计算出一个数字信息所对应的长度固定的字符串，它对长度不超过264位的消息产生160位的消息摘要。SHA家族的5个算法分别是SHA-1、SHA-224、SHA-256、SHA-384和SHA-512。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

认证技术

3. 数字证书

数字证书又称为数字标识，是由认证中心（CA）签发的对用户的公钥的认证。数字证书的内容应包括CA的信息、用户信息、用户公钥、CA签发时间和有效期等。任何一个用户只要得到CA的公钥，就可以得到CA为该用户签署的数字证书。

4. 身份认证

用户的身份认证是许多应用系统的第一道防线，其目的在于识别用户的合法性，从而阻止非法用户访问系统。

（1）口令认证。用户名/密码是最简单也是最常用的身份认证方法。

（2）动态口令认证。用户密码按照时间或使用次数不断变化、每个密码只能使用一次。

（3）生物特征识别。分为身体特征和行为特征。身体特征包括指纹、视网膜、虹膜、脸型、手的血管和脱氧核糖核酸等；行为特征包括签名、语音和行走步态等。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

密钥管理体制

密钥管理是指处理密钥自产生到销毁的整个过程中的有关问题，包括系统的初始化、密钥的产生、存储、备份/恢复、装入、分配、保护、更新、控制、丢失、吊销和销毁等。

1.KMI机制

KMI设定一个密钥分发中心（KDC）来负责发放密钥，这种结构经历了从静态分发到动态分发的发展过程，是密钥管理的重要手段。

2.PKI机制

完整的PKI系统必须具有CA、数字证书库、密钥备份及恢复系统、证书作废系统和应用接口等基本构成部分。PKI与KMI的比较如表所示。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

密钥管理体制

比较项目	PKI	KMI
作用特性	良好的扩展性，适于开放业务	很好的封闭性，适于专用业务
服务功能	只提供数字签名服务	提供数据加密和数字签名功能
信任逻辑	第三方管理模式	集中式的主管方管理模式
负责性	个人负责的技术体系	单位负责制
应用角度	主外	主内

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.3 通信与网络安全技术

防火墙

虚拟专用网

安全协议

单点登录技术

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

防火墙

1. 防火墙的功能

防火墙一般具有访问控制功能、内容控制功能、全面的日志功能、集中管理功能、自身的安全和可用性、流量控制、网络地址转换、虚拟专用网（VPN）等功能。

2. 防火墙的分类

从总体上来说，防火墙技术可分为网络级防火墙和应用级防火墙两类。在实际应用中，可以根据不同应用对防火墙进行更详细的划分，包过滤型防火墙、电路级网关型防火墙、应用网关型防火墙、代理服务型防火墙、状态检测型防火墙和自适应代理型防火墙。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

防火墙

3. 防火墙的体系结构

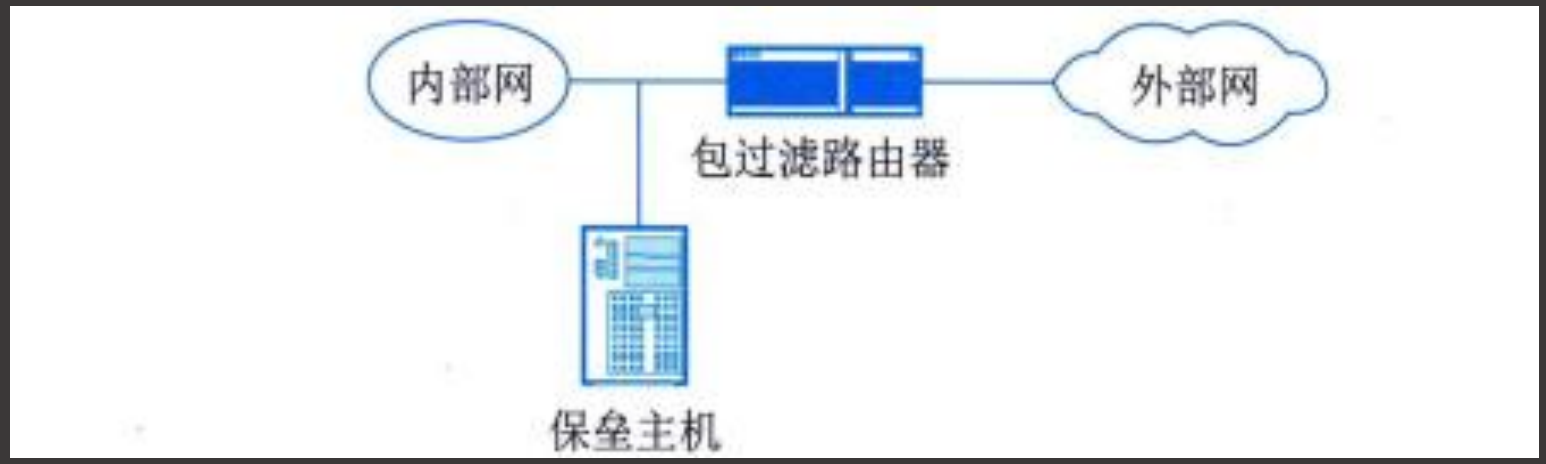
（1）双宿/多宿主机模式。是一种拥有两个或多个连接到不同网络上的网络接口的防火墙。通常用一台装有两块或多块网卡的堡垒主机做防火墙，两块或多块网卡各自与内部网和外部网相连，一般采用代理服务的办法，必须禁止网络层的路由功能。



微信公众号：规格严考；bilibili：枯燥的工程师

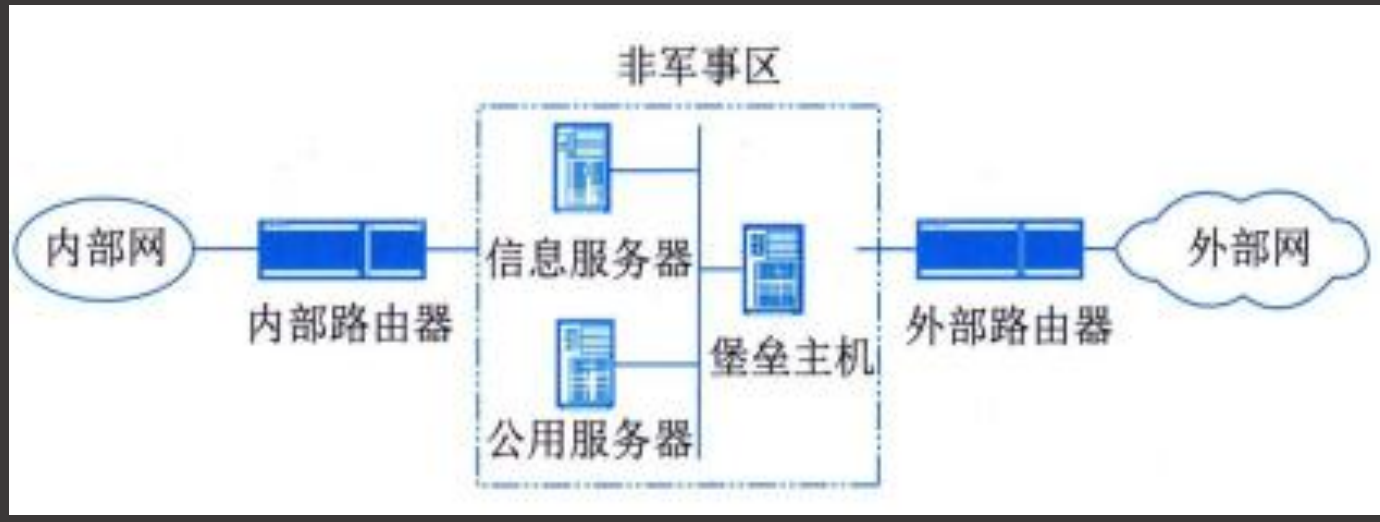
防火墙

（2）屏蔽主机模式。屏蔽主机模式的防火墙由包过滤路由器和堡垒主机组成。该模式的主要特点是，将堡垒主机安装在内部网络上，通常在路由器上设立过滤规则，使这个堡垒主机成为从外部网络唯一可直接到达的主机，这确保了内部网络不受未被授权的外部用户的攻击。实现了网络层和应用层的安全，比单独的包过滤或应用网关代理更安全。



防火墙

（3）屏蔽子网模式。屏蔽子网模式采用了两个包过滤路由器和一个堡垒主机，在内外网络之间建立一个被隔离的子网，称为非军事区（DMZ）或边界网络。屏蔽子网模式的特点是，网络管理员将堡垒主机、Web服务器等公用服务器放在DMZ中。内部网络和外部网络均可访问屏蔽子网，但禁止它们穿过屏蔽子网通信。即使堡垒主机被入侵者控制，内部网仍能受到内部包过滤路由器的保护。多个堡垒主机运行各种代理服务，可以更有效地提供服务。



淘宝搜索：系统分析师 规格严考

防火墙

4. 防火墙的局限性

（1）限制或关闭一些有用但存在安全缺陷的网络服务，给用户带来了使用上的不便。

（2）目前，防火墙对于来自网络内部的攻击还无能为力。

（3）防火墙不能防范不经过防火墙的攻击，

（4）防火墙对用户不完全透明，可能带来传输延迟、瓶颈和单点失效等问题。

（5）防火墙不能完全防止受病毒感染的文件或软件的传输，由于病毒的种类繁多，如果要让防火墙完成对所有病毒代码的检查，防火墙的效率就会降低到不能忍受的程度。

微信公众号：规格严考；bilibili：枯燥的工程师

虚拟专用网

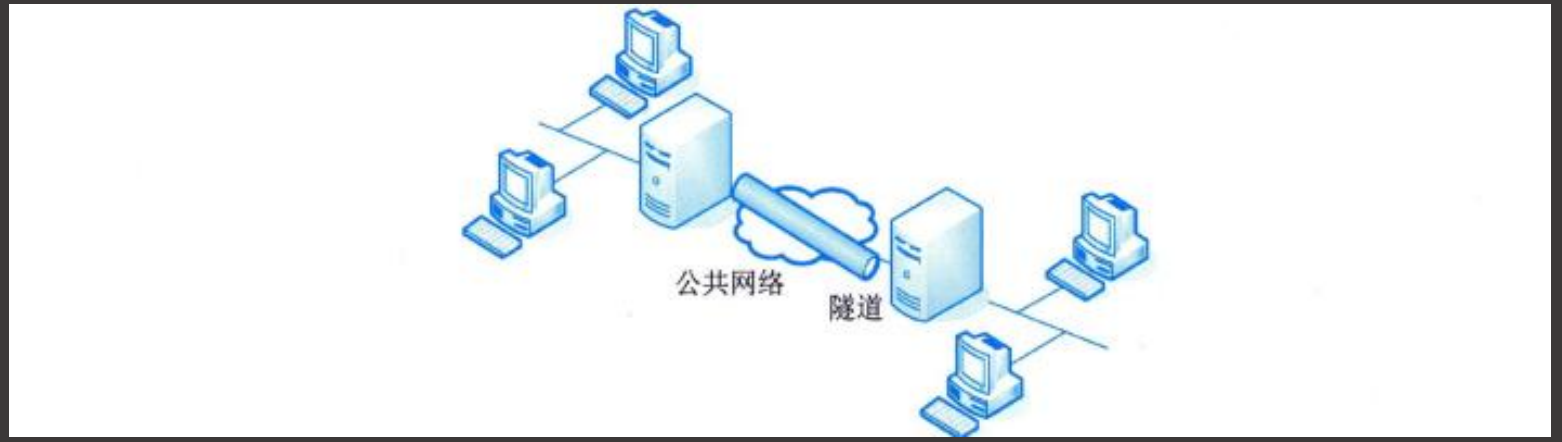
虚拟专用网（VPN）是一个虚信道，它可用来连接两个专用网，通过可靠的加密技术保证其安全性，并且是作为公共网络的-部分存在的。

1. VPN的关键技术

（1）隧道技术；（2）加解密技术；（3）密钥管理技术；

（4）身份认证技术；（5）访问控制技术；

2. PPP会话过程：创建PPP链路、用户验证、PPP回叫控制和调用网络层协议。



淘宝搜索：系统分析师 规格严考

安全协议

1. SSL

SSL是一个传输层的安全协议，用于在Interet上传送机密文件。SSL协议由握手协议、记录协议和警报协议组成。SSL主要提供三个方面的服务，分别是用户和服务器的合法性认证、加密数据以隐藏被传送的数据和保护数据的完整性。SSL使用40位关键字作为RC4流加密算法，这对于商业信息的加密是合适的。SSL是一个保证计算机通信安全的协议，对通信对话过程进行安全保护，其实现过程主要经过如下几个阶段：

（1）接通阶段。客户机通过网络向服务器打招呼，服务器回应。

（2）密码交换阶段。客户机与服务器之间交换双方认可的密码。

（3）会谈密码阶段。客户机器与服务器间产生彼此交谈的会谈密码。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

安全协议

（4）检验阶段。客户机检验服务器取得的密码。

（5）客户认证阶段。服务器验证客户机的可信度。

（6）结束阶段。客户机与服务器之间相互交换结束的信息。

2. HTTPS

HTTPS是以安全为目标的HTTP通道，简单地说，HTTPS是HTTP的安全版。SSL极难窃听可对中间人攻击提供一定的合理保护。HTTPS是一个统一资源标识符（URI）语法体系，句法类同HTTP体系，用于安全的HTTP数据传输。HTTPS实际上应用了SSL作为HTTP应用层的子层，HTTPS使用端口443，而不是像HTTP那样使用端口80来和TCP/IP进行通信。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

安全协议

3. PGP

PGP是一个基于RSA的邮件加密软件，可以用它对邮件保密以防止非授权者阅读，它还能对邮件加上数字签名，从而使收信人可以确信邮件发送者。

4. IPSec

IPSec是一个工业标准网络安全协议，为网络通信提供透明的安全服务，保护TCPIP通信免遭窃听和篡改，可以有效抵御网络攻击，同时保持易用性。IPSec有两个基本目标，分别是保护IP数据包安全和为抵御网络攻击提供防护措施。IPSec结合密码保护服务、安全协议组和动态密钥管理三者来实现上述两个目标。IPSec是针对IPv4和IPv6的，其主要特征是可以支持IP级所有流量的加密和/或认证，增强所有分布式应用的安全性。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

单点登录技术

1. 单点登录系统的概念

单点登录（SSO）技术是通过用户的一次性认证登录，即可获得需要访问系统和应用软件的授权。单点登录系统采用基于数字证书的加密和数字签名技术，基于统一策略的用户身份认证和授权控制功能，对用户实行集中、统一的管理和身份认证，以区别不同的用户和信息访问者，并作为各应用系统的统一登录入口，同时，为通过身份认证的合法用户签发针对各个应用系统的登录票据，从而实现“一点登录，多点漫游”。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

单点登录技术

2. SSO系统的特征与功能

（1）常规特征。支持多种系统、设备和接口。

（2）终端用户管理灵活性。包括通常的账号创建、口令管理和用户识别。

（3）应用管理灵活性。

（4）移动用户管理。保证用户在不同的地点对信息资源进行访问。

（5）加密和认证。加密保证信息在终端用户和安全服务器之间传输时的安全性；认证保证用户的真实性。

（6）访问控制。保证只有用户被授权访问的应用可以提供给用户。

（7）可靠性和性能。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

单点登录技术

3. Kerberos机制

Kerberos是一种网络身份认证协议，该协议的基础是基于信任第三方，它提供了在开放型网络中进行身份认证的方法，认证实体可以是用户也可以是用户服务。 Kerberos的安全机制在于首先对发出请求的用户进行身份验证，确认其是否是合法的用户如是合法的用户，再审核该用户是否有权对其所请求的服务或计算机进行访问。

4. 外壳脚本机制

外壳脚本机制通过原始认证进入系统外壳，然后外壳就会激发各种专用平台的脚本，来激活目标平台的账号和资源的访问。这种方式简化了用户的登录，但它没有提供同步的口令字以及其他管理方法。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.4 系统访问控制技术

访问控制概述

访问控制模型

访问控制分类

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

访问控制概述

访问控制是策略和机制的集合，它允许对限定资源的授权访问。访问控制技术也可以保护资源，防止那些无权访问资源的用户的恶意访问。

1. 访问控制的要素

（1）主体。主体是可以对其他实体施加动作的主动实体，有时也称为用户或访问者。

（2）客体。客体是接受其他实体访问的被动实体。

（3）控制策略。控制策略是主体对客体的操作行为集合约束条件集，直接定义了主体对客体的作用行为和客体对主体的条件约束。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

访问控制概述

2. 访问控制的策略

（1）登录访问控制策略。登录访问控制为系统访问提供了第一层访问控制，它控制哪些用户能够登录系统并获取资源，控制准许用户登录时间和具体工作站。

（2）操作权限控制策略。系统管理员能够通过设置，指定用户和用户组可以访问系统中的哪些服务器和计算机，可以在服务器或计算机上操作哪些程序、目录、文件和其他资源。

（3）目录安全控制策略。系统应该允许管理员控制用户对目录、文件和设备的操作。

（4）属性安全控制策略。属性安全控制策略允许将设定的访问属性与服务器的文件、目录和设备联系起来。

（5）服务器安全控制策略。系统允许在服务器控制台上执行一系列操作。用户通过控制台可以加载和卸载系统模块，可以安装和删除软件。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

访问控制模型

1. Bell-LaPadula模型

BLP模型是第一个正式的安全模型，该模型基于强制访问控制（MAC）系统，是典型的信息保密性多级安全模型，主要应用于军事系统中。将数据和用户安全等级划分为公开、受限、秘密、机密和高密5个等级。

BLP模型基于两种规则来保障数据的机密度与敏感度，分别是下读和上写。下读是指主体不可读取安全级别高于它的数据，上写是指主体不可写入安全级别低于它的数据。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

访问控制模型

2.Lattice模型

在Lattice模型中，每个资源和用户都服从于一个安全类别。Lattice模型通过划分安全边界对BLP模型进行了扩充，它将用户和资源进行分类，并允许它们之间交换信息，这是多边安全体系的基础。在执行访问控制功能时，Latice模型本质上与BLP模型是相同的，而Lattice模型更注重形成“安全集束”。BLP模型中的上读和下写原则在此仍然适用，但前提条件必须是各对象位于相同的安全集束中。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

访问控制模型

3. Biba模型

Biba访问控制模型对数据提供了分级别的完整性保证，类似于BLP保密性模型，Biba模型也使用MAC系统。Biba模型基于两种规则来保障数据的完整性与保密性，分别是上读和下写。上读是指主体不能读取安全级别低于它的数据，下写是指主体不能写入安全级别高于它的数据。

微信公众号：规格严考；bilibili：枯燥的工程师

访问控制分类

1. 自主访问控制DAC

自主访问控制是目前计算机系统中实现最多的访问控制机制，它是在确认主体身份以及它们所属组的基础上，对访问进行限定的一种方法。

2. 强制访问控制MAC

MAC的基本思想是每个主体都有既定的安全属性，每个客体也都有既定的安全属性，主体对客体是否能执行特定的操作取决于两者安全属性之间的关系。

3. 基于角色的访问控制RBAC

基于角色的访问控制技术由于其对角色和层次化管理的引进，特别适用于用户数量庞大系统功能不断扩展的大型系统。在RBAC中，在用户和访问许可权之间引入了角色的概念，用户与特定的一个或多个角色相联系，角色与一个或多个访问许可权相联系。

淘宝搜索：系统分析师 规格严考

访问控制分类

4. 基于任务的访问控制TBAC

它采用面向任务的观点，从任务的角度来建立安全模型和实现安全机制，在任务处理的过程中提供动态实时的安全管理。TBAC是一种动态安全模型。TBAC模型由工作流、授权结构体、授权步和许可集4个部分组成。

5. 基于对象的访问控制OBAC

控制策略和控制规则是基于对象的访问控制的核心，在OBAC模型中，将ACL与受控对象及其属性相关联，并将访问控制选项设计成为用户、组或角色及其对应权限的集合。同时，允许对策略和规则进行复用、继承和派生操作。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.5 容灾与业务持续

灾难恢复技术

灾难恢复规划

业务持续性规划

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

灾难恢复技术

灾难恢复是指为了将信息系统从灾难造成的故障或瘫痪状态恢复到可正常运行状态，并将其支持的业务功能从灾难造成的不正常状态恢复到可接受状态，而设计的活动和流程。

1. 灾难恢复的技术指标

灾难恢复的两个关键概念是恢复点目标（RPO）和恢复时间目标（RTO）。RPO是指灾难发生后，容灾系统能将数据恢复到灾难发生前时间点的数据，它是衡量企业在灾难发生后会丢失多少数据的指标；RTO则是指灾难发生后从系统宕机导致业务停顿时刻开始，到系统恢复至可以支持业务部门运作，业务恢复运营之时此两点之间的时间。RPO可简单描述为企业能容忍的最大数据丢失量，RTO可简单描述为企业能容忍的恢复时间。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

灾难恢复技术

2. 灾难恢复等级

在《信息安全技术信息系统灾难恢复规范》（GB/T20988-2007）中，将灾难恢复划分为6个等级。第1级为基本支持，第2级为备用场地支持，第3级为电子传输和部分设备支持，第4级为电子传输及完整设备支持，第5级为实时数据传输及完整设备支持，第6级为数据零丢失和远程集群支持。

3. 容灾技术的分类

从对系统的保护程度来分，可以将容灾系统分为数据容灾和应用容灾。

数据容灾指灾难发生后可以确保用户原有的数据不会丢失或遭到破坏。应用容灾是在数据容灾的基础上，再将执行应用处理能力复制一份，也就是说，在备份站点同样构建一套应用系统。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

灾难恢复规划

1. 灾难恢复需求的确定

包括进行风险分析、业务影响评估和确定灾难恢复目标三个方面的工作。

2. 灾难恢复策略的制定

支持灾难恢复各个等级所需的资源包括7个要素，分别是数据备份系统、备用数据处理系统、备用网络系统、备用基础设施、技术支持能力、运行维护管理能力和灾难恢复预案。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

灾难恢复规划

3. 灾难恢复策略的实现

（1）灾难备份系统技术方案的实现。

（2）灾难备份中心的选择和建设。

（3）技术支持能力的实现。

（4）运行维护管理能力的实现。

（5）灾难恢复预案的实现。

4. 灾难恢复预案的制定

灾难恢复预案的制定过程如下：

（1）起草。（2）评审。（3）测试。（4）修订。（5）审核和批准。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

业务持续性规划

业务持续性规划（BCP）是在非计划的业务中断情况下，使业务继续或恢复其关键功能的一系列预定义的过程。

1. 实施BCP的阶段

需要经过8个主要阶段：项目启动、风险评估与消减业务影响分析、业务持续性策略、开发BCP、人员培训与训练、测试与演练、BCP的持续维护及变更管理。

2. BCP主体框架

BCP本身也应该看作是一个流程，企业范围内的BCP流程主体框架主要由4个部分组成，包括：灾难恢复规划（DRP）、业务恢复规划（BRP）、危机管理规划（CMP）和持续可用性（CA）。为了衡量BCP流程，可以使用BCP平衡计分卡，内容包括价值综述、价值计划、BCP风险度量标准、执行协议和有效方法。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.6 安全管理措施

安全管理的内容

安全审计

私有信息保护

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

安全管理的内容

1. 密码管理

为了保护计算机和信息系统中的敏感信息，有选择地采取技术上的和相关程序上的安全防护措施，是企业在安全管理体系中的迫切需求。

2. 网络管理

包括配置管理、性能管理、安全管理、计费管理和故障管理等。

3. 设备管理

包括设备的选型、检测、安装、登记、使用、维护和存储管理等方面的内容。

4. 人员管理

人员管理的核心是要确保有关业务人员的思想素质、职业道德和业务技能。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

安全审计

安全审计对主体访问和使用客体的情况进行记录和审查，以保证安全规则被正确执行，并帮助分析安全事故产生的原因。

1. 安全审计的基本要素

（1）控制目标。指企业根据具体的计算机应用，结合单位实际制定出的安全控制要求。

（2）安全漏洞。指系统的安全薄弱环节，容易被干扰或破坏的地方。

（3）控制措施。指企业为实现其安全控制目标所制定的安全控制技术、配置方法及各种规范制度。

（4）控制测试。将企业的各种安全控制措施与预定的安全标准进行一致性比较，评价企业安全措施的可依赖程度。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

2. CC标准

由ISO提出的通用准则（CC）将安全审计功能分为6个部分，分别是安全审计自动响应、安全审计数据生成、安全审计分析、安全审计浏览、安全审计事件选择和安全审计事件存储。

私有信息保护

私有信息是个人隐私的一部分，应征得信息的主体同意，才可在限定的目的和范围内使用。目前，由于我国还没有保护私有信息的法律，公民和社会普遍缺乏私有信息保护意识，私有信息一度被不合理地公开甚至滥用。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.7 系统可靠性

系统故障模型

系统可靠性指标

系统可靠性分析

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.7 系统可靠性

根据国家标准《系统与软件工程系统与软件质量要求和评价（SQuaRE）第10部分：系统与软件质量型》（GB/T25000.10-2016）的规定，系统可靠性包括成熟性、容错性、易恢复性和可靠性的依从性4个子特性。其中，成熟性是指系统避免因错误的发生而导致失效的能力；容错性是指在系统发生故障或违反指定接口的情况下，系统维持规定的性能级别的能力：易恢复性是指在系统发生失效的情况下，重建规定的性能级别并恢复受直接影响的数据的能力：可靠性的依从性是指系统依附于与可靠性相关的标准、约定或规定的能力。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

系统故障模型

1. 逻辑级的故障

逻辑级的故障是指硬件逻辑上出现的故障，一般是指电路中元器件的输入或输出固定为0（或1）。例如，某线接地、电源短路或元件失效等都可能造成逻辑级的故障。

2. 数据结构级的故障

（1）独立差错。表现为使一个二进制位发生改变。

（2）算术差错。表现为使一个数据的值增加或减少。

（3）单向差错。表现为使一个二进制向量中的某些位朝一个方向改变。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

系统故障模型

3. 软件故障和软件差错

软件故障是指软件设计过程造成的与设计说明的不一致，软件故障在数据结构或程序输出中的表现称为软件差错。与硬件不同，软件不会因为环境应力而疲劳，也不会因为时间的推移而衰老。因此，软件故障只与设计有关。

4. 系统级的故障

故障在系统级上的表现为功能错误，即系统输出与系统设计说明的不一致。如果系统输出无故障保护机构，则故障在系统级上的表现就会造成系统失效。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

系统可靠性指标

1. 平均无故障时间：

产品在规定的条件下和规定的时间内，完成规定功能的能力称为可靠性。

平均无故障时间MTTR=系统运行时间/故障次数

λ为失效率，则MTTR=1/λ

2. 平均故障修复时间

平均故障修复时间MTTF=系统故障耗时/故障次数

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

系统可靠性指标

3. 平均故障间隔时间

因为两次故障之间必然有修复行为，因此，平均故障间隔时间（MTBF）中应包含MTTR。

$$MTBF=MTTR+MTTF$$

在实际应用中，一般MTTR的值很小，所以通常认为MTBF≈MTTF。

4. 系统可用性

系统可用性是指在某个给定时间点上系统能够按照需求执行的概率，其公式为：

$$系统可用性=MTTF/（MTTR+MTTF）\times 100\%=MTTF/MTBF\times 100\%$$

微信公众号：规格严考；bilibili：枯燥的工程师

系统可靠性分析

1. 串联系统

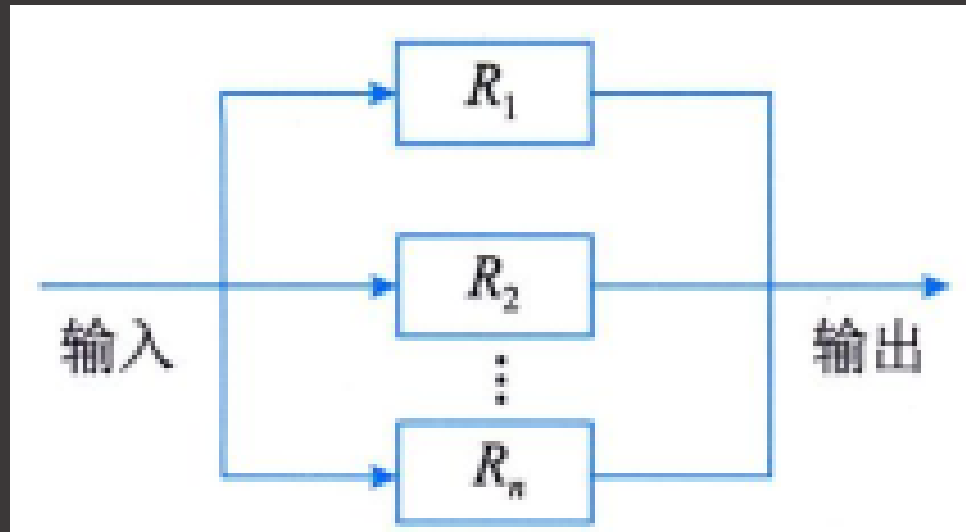
各个子系统可靠度分别用R1，…，Rn表示，则系统的可靠度为：

R=R1×…×Rn



2. 并联系统

各个子系统可靠度分别用R1，…，Rn表示，则系统的可靠度为：R=1-（1-R1）×…×（1-Rn）.

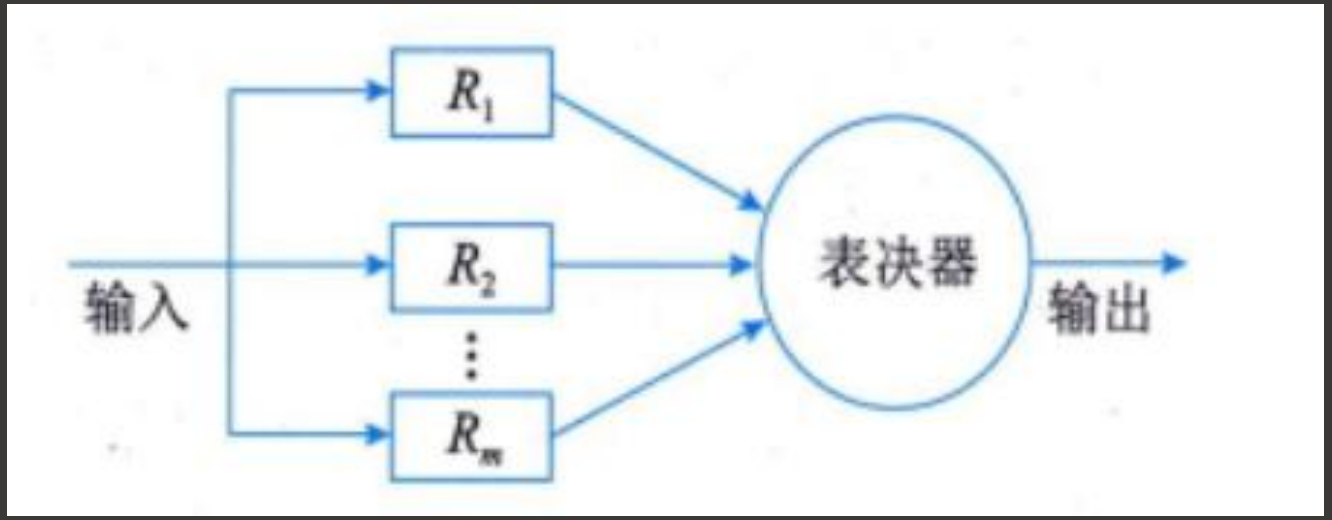


淘宝搜索：系统分析师 规格严考

系统可靠性分析

3. 模冗余系统

模冗余系统由m（m=2n+1，n>1）个相同的子系统和一个表决器组成，经过表决器表决后，m个子系统中占多数相同结果的输出作为系统的输出。



微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.8 冗余技术

冗余技术的分类

冗余系统

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

冗余技术的分类

1. 结构冗余

（1）静态冗余。又称为屏蔽冗余或被动冗余，常用的有三模冗余和多模冗余。

（2）动态冗余。又称为主动冗余，通过故障检测、故障定位及故障恢复达到容错目的。

（3）混合冗余。混合冗余技术是将静态冗余和动态冗余结合起来，且取二者之长处。

2. 信息冗余

在实现正常功能所需要的信息外，再添加一些信息，以保证运行结果正确性的方法。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

冗余技术的分类

3. 时间冗余

重复多次进行相同的计算，称为重复执行，达到故障检测的目的。

4. 冗余附加

冗余附加是指为实现上述冗余技术所需的资源和技术，包括程序、指令、数据，以及存放和调用它们的空间等。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

冗余系统

冗余系统在处理运行中出现的故障时，大致有以下10个步骤：

（1）故障检测。

（2）故障屏蔽。

（3）故障限制。

（4）复执。

（5）故障诊断。

（6）系统重配置。

（7）系统恢复。

（8）系统重新启动。

（9）修复。

（10）系统重组合。

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

9.9 软件容错技术

N 版本程序设计

恢复块方法

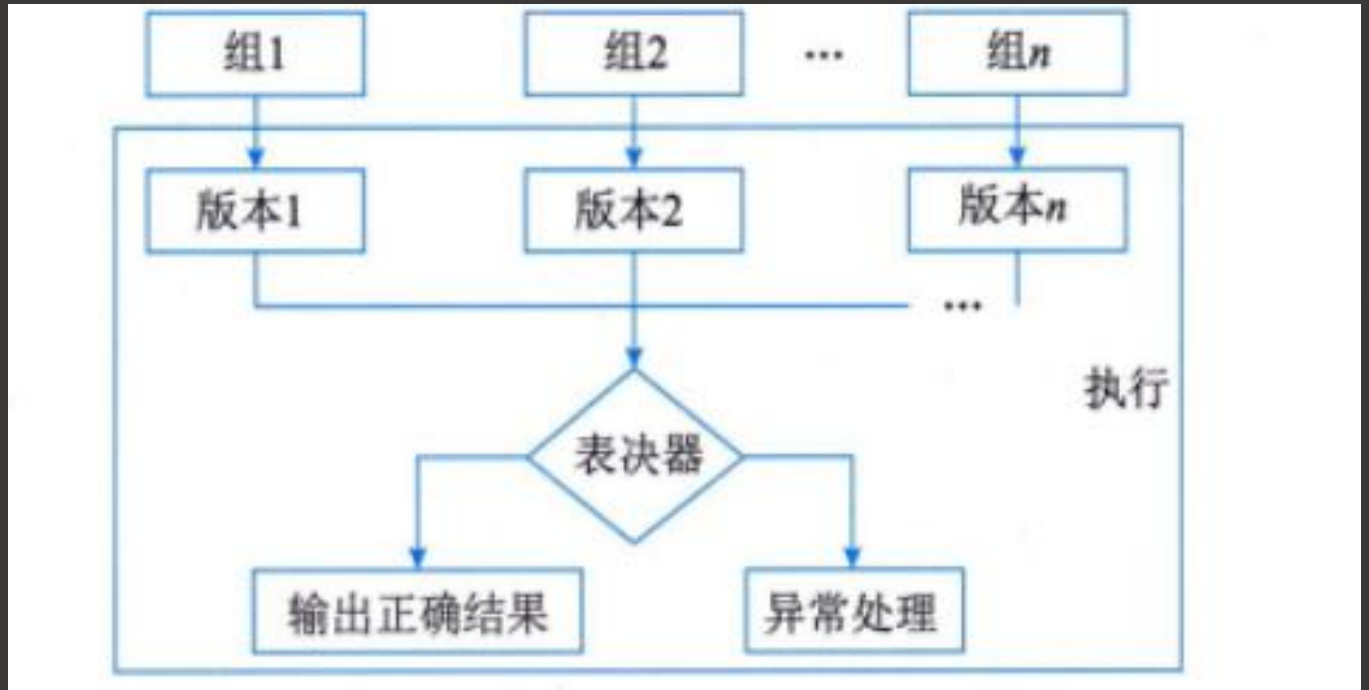
防卫式程序设计

微信公众号：规格严考；bilibili：枯燥的工程师

N版本程序设计

容错是指系统在运行过程中发生一定的硬件故障或软件错误时，仍能保持正常工作而不影响正确结果的一种性能或措施。容错技术主要是采用冗余方法来消除故障的影响。

N版本程序设计是一种静态的故障屏蔽技术，采用前向恢复的策略。



淘宝搜索：系统分析师 规格严考

N版本程序设计

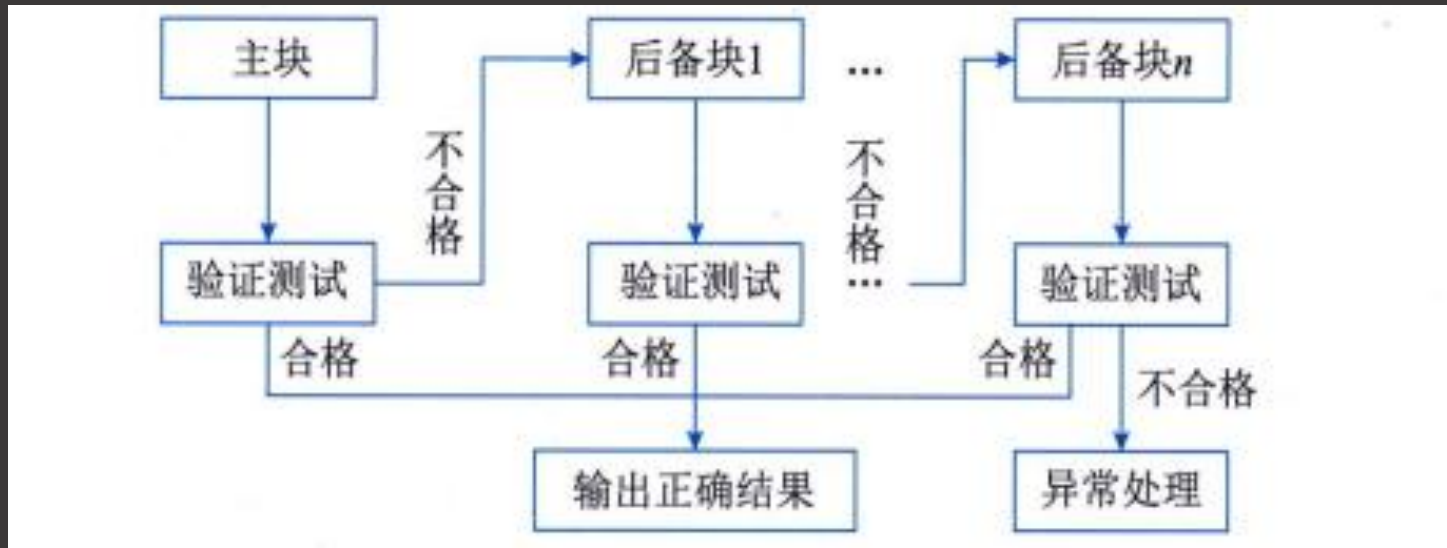
设计思想是用n个具有相同功能的程序同时执行一项计算，结果通过多数表决来选择。其中n个版本的程序必须由不同的人（小组）独立设计，使用不同的方法、不同的设计语言、不同的开发环境和工具来实现，目的是减少n个版本的程序在表决点上相关错误的概率。

微信公众号：规格严考；bilibili：枯燥的工程师

恢复块方法

恢复块方法是一种动态故障屏蔽技术，采用后向恢复策略。

恢复块方法提供具有相同功能的主块和几个后备块，一个块就是一个执行完整的程序段，主块首先投入运行，结束后进行验证测试，如果没有通过验证测试，系统经现场恢复后由后备块1运行。后备块1运行结束后也进行验证测试，如果没有通过验证测试，系统经现场恢复后由后备块2运行。重复这一过程，可以重复到耗尽所有的后备块，或者某个程序故障行为超出了预料，从而导致不可恢复的后果。



淘宝搜索：系统分析师 规格严考

恢复块方法

比较项目	恢复块方法	N 版本程序设计
硬件运行环境	单机	多机
错误检测方法	验证测试程序	表决
恢复策略	后向恢复	前向恢复
实时性	差	好

微信公众号：规格严考；bilibili：枯燥的工程师

淘宝搜索：系统分析师 规格严考

防卫式程序设计

N版本程序设计和恢复块方法都是基于设计冗余的思想，防卫式程序设计是一种不采用任何传统的容错技术就能实现软件容错的方法，对于程序中存在的错误和不一致性，防卫式程序设计的基本思想是通过在程序中包含错误检查代码和错误恢复代码，使得一旦发生错误，程序就能撤销错误状态，恢复到一个已知的正确状态中去。其实现策略包括错误检测、破坏估计和错误恢复三个方面。

微信公众号：规格严考；bilibili：枯燥的工程师

谢谢！